Access Control Procedure - OT Environment

1. Purpose

This procedure outlines how to detect, report, and respond to suspected phishing emails to minimize cybersecurity risks in the plant environment, especially where IT and OT systems interact.

2. Scope

Applies to all personnel with access to:
- Company email systems (including webmail and mobile access)
- Engineering and operator workstations connected to OT networks
- Remote vendor access tools with email notifications

3. Roles and Responsibilities

All Employees: Identify and report phishing attempts immediately
OT Security Manager: Investigate, respond, and report phishing incidents
IT Support Team: Email filtering, quarantining, and forensic support
HR / Training: Conduct phishing awareness and training sessions

4. Procedure

4.1 Identification
- Employees must be trained to identify common phishing indicators:
  - Suspicious sender address or domain
  - Urgent or threatening language
  - Unexpected attachments or links
  - Requests for credentials or payment info
- If a user suspects a phishing email:
  - Do not click on any links or open attachments.
  - Do not forward the email to others.
  - Report via 'Report Phishing' or forward to: security@[company].com

4.2 Containment
- IT/OT security isolates the email from mailboxes.
- If a link was clicked or attachment opened:
  - Disconnect from the network.
  - Notify OT Security Manager.
  - Begin endpoint analysis.

4.3 Investigation
- Review email headers, source, and links.
- Check if similar emails reached others.
- Analyze attachments in a sandbox.
- Review logs for unauthorized activity.

4.4 Remediation

- Remove malicious email from mailboxes.
- Reimage or clean infected machines.
- Reset affected credentials.
- Block sender domains or URLs.

4.5 Communication
- Communicate with affected users.
- Notify leadership if OT may be impacted.
- Follow external notification protocols if needed.

4.6 Awareness & Training
- Annual phishing awareness training is mandatory.
- Simulated phishing tests conducted twice a year.
- HR tracks training completion.

5. Enforcement

Failure to follow this procedure may result in disciplinary action. Repeated negligent behavior may be escalated to HR and management.

6. References

- IEC 62443-2-1: Security Program Requirements for IACS Asset Owners
- IEC 62443-4-2: Technical Security Requirements for IACS Components
- [Company] Email and Acceptable Use Policy